

Vulnerability

Assessment Report

20th April 2026

Scenario

Review the following scenario. Then complete the step-by-step instructions.

You are a newly hired cybersecurity analyst for an e-commerce company. The company stores information on a remote database server, since many of the employees work remotely from locations all around the world. Employees of the company regularly query, or request, data from the server to find potential customers. The database has been open to the public since the company's launch three years ago. As a cybersecurity professional, you recognize that keeping the database server open to the public is a serious vulnerability.

You are tasked with completing a vulnerability assessment of the situation to communicate the potential risks to decision makers at the company. You must create a written report that explains how the vulnerable server is a risk to business operations and how it can be secured.

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 20XX to August 20XX. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

Purpose

The database is valuable because it is the engine that drives the business. The organisation's employees query it daily and they depend on it daily to find potential customers and without it operations will grind to a halt.

It is also important that the organisation secures the database when it gets to the wrong hands, it is a breach of trust and according to the NIST SP 800-30 it can also cause damage to the organisation's information system.

if an attacker gets hold of these data and disables it, employees can't query the database again and no customer will be served, company wouldn't make money, maybe not permanently but the business operation will come to a complete standstill

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
<i>Malicious Software</i>	<i>encrypts critical data and disrupts system availability</i>	1	3	9
<i>Cyber Criminal</i>	<i>Obtain sensitive information via exfiltration</i>	3	3	9
<i>Insider Threat</i>	<i>Alter/Delete critical information</i>	2	3	6

Approach

This database is attractive to cybercriminals because it is public, it removes the barrier a criminal would normally have to overcome. anybody can access it and because of it being public it is easier for them to look for vulnerabilities to exploit. Since there is no access control/separation of duties, they all have direct access without restrictions to the entire database. an employee could be compromised. The database has been open to the public for 3 years which is a long time, automated malware could be sniffing around for these years with uninterrupted access to probe and scan for vulnerabilities, looking for what to exploit. It is not just a risk, it is almost inevitable.

Remediation Strategy

Least privilege means each employee only accesses what they need for their specific role, nothing more. A customer service employee has no business accessing financial records, and a finance employee doesn't need marketing data. MFA adds that critical second layer, even if an attacker steals an employee's username and password, they still can't get in without the OTP or biometric verification. It directly addresses the risk of unauthorised access to the publicly open database. Accounting creates a full audit trail, every access, every query, every deletion is logged with a username and timestamp. If something goes wrong the IT team can trace exactly who did what and when. It also deters insider threats because employees know their actions are being monitored and recorded.